



FindMyFlick ZAP Report1

Sites: <https://telem-edge.smartscreen.microsoft.com> <https://data-edge.smartscreen.microsoft.com> <https://nav-edge.smartscreen.microsoft.com> <https://www.findmyflick.com> <http://www.findmyflick.com>

ZAP Version: 2.16.1

ZAP by [Checkmarx](#)

Summary of Alerts

Risk Level	Number of Alerts
High	0
Medium	2
Low	3
Informational	3

Alerts

Name	Risk Level	Number of Instances
Content Security Policy (CSP) Header Not Set	Medium	4
Missing Anti-clickjacking Header	Medium	4
Strict-Transport-Security Header Not Set	Low	4
X-Content-Type-Options Header Missing	Low	3
ZAP is Out of Date	Low	4
Information Disclosure - Suspicious Comments	Informational	1
Modern Web Application	Informational	4
User Agent Fuzzer	Informational	24

Alert Detail

Medium	Content Security Policy (CSP) Header Not Set
Description	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.
URL	http://www.findmyflick.com
Method	GET

Attack	
Evidence	
Other Info	
URL	https://www.findmyflick.com/
Method	GET
Attack	
Evidence	
Other Info	
URL	https://www.findmyflick.com/robots.txt
Method	GET
Attack	
Evidence	
Other Info	
URL	https://www.findmyflick.com/sitemap.xml
Method	GET
Attack	
Evidence	
Other Info	
Instances	4
Solution	Ensure that your web server, application server, load balancer, etc. is configured to set the Content-Security-Policy header.
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html https://www.w3.org/TR/CSP/ https://w3c.github.io/webappsec-csp/ https://web.dev/articles/csp https://caniuse.com/#feat=contentsecuritypolicy https://content-security-policy.com/
CWE Id	693
WASC Id	15
Plugin Id	10038

Medium	Missing Anti-clickjacking Header
Description	The response does not protect against 'ClickJacking' attacks. It should include either Content-Security-Policy with 'frame-ancestors' directive or X-Frame-Options.
URL	http://www.findmyflick.com
Method	GET
Attack	
Evidence	
Other Info	
URL	https://www.findmyflick.com/
Method	GET

Attack	
Evidence	
Other Info	
URL	https://www.findmyflick.com/robots.txt
Method	GET
Attack	
Evidence	
Other Info	
URL	https://www.findmyflick.com/sitemap.xml
Method	GET
Attack	
Evidence	
Other Info	
Instances	4
Solution	Modern Web browsers support the Content-Security-Policy and X-Frame-Options HTTP headers. Ensure one of them is set on all web pages returned by your site/app. If you expect the page to be framed only by pages on your server (e.g. it's part of a FRAMESET) then you'll want to use SAMEORIGIN, otherwise if you never expect the page to be framed, you should use DENY. Alternatively consider implementing Content Security Policy's "frame-ancestors" directive.
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options
CWE Id	1021
WASC Id	15
Plugin Id	10020

Low	Strict-Transport-Security Header Not Set
Description	HTTP Strict Transport Security (HSTS) is a web security policy mechanism whereby a web server declares that complying user agents (such as a web browser) are to interact with it using only secure HTTPS connections (i.e. HTTP layered over TLS/SSL). HSTS is an IETF standards track protocol and is specified in RFC 6797.
URL	https://data-edge.smartscreen.microsoft.com/api/browser/edge/data/settings/3
Method	POST
Attack	
Evidence	
Other Info	
URL	https://data-edge.smartscreen.microsoft.com/api/browser/edge/data/toptraffic/3
Method	POST
Attack	
Evidence	
Other Info	
URL	https://nav-edge.smartscreen.microsoft.com/api/browser/edge/navigate/3

Method	POST
Attack	
Evidence	
Other Info	
URL	https://telem-edge.smartscreen.microsoft.com/api/browser/edge/telemetry/3
Method	POST
Attack	
Evidence	
Other Info	
Instances	4
Solution	Ensure that your web server, application server, load balancer, etc. is configured to enforce Strict-Transport-Security.
Reference	https://cheatsheetseries.owasp.org/cheatsheets/HTTP_Strict_Transport_Security_Cheat_Sheet.html https://owasp.org/www-community/Security-Headers https://en.wikipedia.org/wiki/HTTP_Strict_Transport_Security https://caniuse.com/stricttransportsecurity https://datatracker.ietf.org/doc/html/rfc6797
CWE Id	319
WASC Id	15
Plugin Id	10035

Low	X-Content-Type-Options Header Missing
Description	The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older versions of Internet Explorer and Chrome to perform MIME-sniffing on the response body, potentially causing the response body to be interpreted and displayed as a content type other than the declared content type. Current (early 2014) and legacy versions of Firefox will use the declared content type (if one is set), rather than performing MIME-sniffing.
URL	https://data-edge.smartscreen.microsoft.com/api/browser/edge/data/settings/3
Method	POST
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	https://data-edge.smartscreen.microsoft.com/api/browser/edge/data/toptraffic/3
Method	POST
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	https://nav-edge.smartscreen.microsoft.com/api/browser/edge/navigate/3
Method	POST
Attack	

Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
Instances	3
Solution	Ensure that the application/web server sets the Content-Type header appropriately, and that it sets the X-Content-Type-Options header to 'nosniff' for all web pages. If possible, ensure that the end user uses a standards-compliant and modern web browser that does not perform MIME-sniffing at all, or that can be directed by the web application /web server to not perform MIME-sniffing.
Reference	https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85) https://owasp.org/www-community/Security_Headers
CWE Id	693
WASC Id	15
Plugin Id	10021

Low	ZAP is Out of Date
Description	The version of ZAP you are using to test your app is out of date and is no longer being updated. The risk level is set based on how out of date your ZAP version is.
URL	http://www.findmyflick.com/robots.txt
Method	GET
Attack	
Evidence	
Other Info	The latest version of ZAP is 2.17.0
URL	https://data-edge.smartscreen.microsoft.com/api/browser/edge/data/settings/3
Method	POST
Attack	
Evidence	
Other Info	The latest version of ZAP is 2.17.0
URL	https://nav-edge.smartscreen.microsoft.com/api/browser/edge/navigate/3
Method	POST
Attack	
Evidence	
Other Info	The latest version of ZAP is 2.17.0
URL	https://telem-edge.smartscreen.microsoft.com/api/browser/edge/telemetry/3
Method	POST
Attack	
Evidence	
Other Info	The latest version of ZAP is 2.17.0
Instances	4

Solution	Download the latest version of ZAP from https://www.zaproxy.org/download/ and install it.
Reference	https://www.zaproxy.org/download/
CWE Id	1104
WASC Id	45
Plugin Id	10116

Informational	Information Disclosure - Suspicious Comments
Description	The response appears to contain suspicious comments which may help an attacker.
URL	https://www.findmyflick.com/assets/index-CJC5SJo1.js
Method	GET
Attack	
Evidence	select
Other Info	The following pattern was used: <code>\bSELECT\b</code> and was detected in likely comment: <code>"//www.w3.org/2000/svg`,a);break;case 2:o=s.createElementNS(`http://www.w3.org/1998/Math/MathML`,a);break;default:switch(a){case`", see evidence field for the suspicious comment /snippet.</code>
Instances	1
Solution	Remove all comments that return information that may help an attacker and fix any underlying problems they refer to.
Reference	
CWE Id	615
WASC Id	13
Plugin Id	10027

Informational	Modern Web Application
Description	The application appears to be a modern web application. If you need to explore it automatically then the Ajax Spider may well be more effective than the standard one.
URL	http://www.findmyflick.com
Method	GET
Attack	
Evidence	<code><script type="module" crossorigin src="/assets/index-CJC5SJo1.js"></script></code>
Other Info	No links have been found while there are scripts, which is an indication that this is a modern web application.
URL	https://www.findmyflick.com/
Method	GET
Attack	
Evidence	<code><script type="module" crossorigin src="/assets/index-CJC5SJo1.js"></script></code>
Other Info	No links have been found while there are scripts, which is an indication that this is a modern web application.
URL	https://www.findmyflick.com/robots.txt
Method	GET
Attack	
Evidence	<code><script type="module" crossorigin src="/assets/index-CJC5SJo1.js"></script></code>
Other Info	No links have been found while there are scripts, which is an indication that this is a modern web application.
URL	https://www.findmyflick.com/sitemap.xml

Method	GET
Attack	
Evidence	<script type="module" crossorigin src="/assets/index-CJC5SJo1.js"></script>
Other Info	No links have been found while there are scripts, which is an indication that this is a modern web application.
Instances	4
Solution	This is an informational alert and so no changes are required.
Reference	
CWE Id	
WASC Id	
Plugin Id	10109

Informational	User Agent Fuzzer
Description	Check for differences in response based on fuzzed User Agent (eg. mobile sites, access as a Search Engine Crawler). Compares the response statuscode and the hashcode of the response body with the original response.
URL	http://www.findmyflick.com/robots.txt
Method	GET
Attack	Mozilla/4.0 (compatible; MSIE 6.0; Windows NT 5.1)
Evidence	
Other Info	
URL	http://www.findmyflick.com/robots.txt
Method	GET
Attack	Mozilla/4.0 (compatible; MSIE 7.0; Windows NT 6.0)
Evidence	
Other Info	
URL	http://www.findmyflick.com/robots.txt
Method	GET
Attack	Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 6.1)
Evidence	
Other Info	
URL	http://www.findmyflick.com/robots.txt
Method	GET
Attack	Mozilla/5.0 (Windows NT 10.0; Trident/7.0; rv:11.0) like Gecko
Evidence	
Other Info	
URL	http://www.findmyflick.com/robots.txt
Method	GET
Attack	Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/75.0.3739.0 Safari/537.36 Edg/75.0.109.0
Evidence	

Other Info	
URL	http://www.findmyflick.com/robots.txt
Method	GET
Attack	Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/91.0.4472.124 Safari/537.36
Evidence	
Other Info	
URL	http://www.findmyflick.com/robots.txt
Method	GET
Attack	Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:93.0) Gecko/20100101 Firefox/91.0
Evidence	
Other Info	
URL	http://www.findmyflick.com/robots.txt
Method	GET
Attack	Mozilla/5.0 (compatible; Googlebot/2.1; +http://www.google.com/bot.html)
Evidence	
Other Info	
URL	http://www.findmyflick.com/robots.txt
Method	GET
Attack	Mozilla/5.0 (compatible; Yahoo! Slurp; http://help.yahoo.com/help/us/ysearch/slurp)
Evidence	
Other Info	
URL	http://www.findmyflick.com/robots.txt
Method	GET
Attack	Mozilla/5.0 (iPhone; CPU iPhone OS 8_0_2 like Mac OS X) AppleWebKit/600.1.4 (KHTML, like Gecko) Version/8.0 Mobile/12A366 Safari/600.1.4
Evidence	
Other Info	
URL	http://www.findmyflick.com/robots.txt
Method	GET
Attack	Mozilla/5.0 (iPhone; U; CPU iPhone OS 3_0 like Mac OS X; en-us) AppleWebKit/528.18 (KHTML, like Gecko) Version/4.0 Mobile/7A341 Safari/528.16
Evidence	
Other Info	
URL	http://www.findmyflick.com/robots.txt
Method	GET
Attack	msnbot/1.1 (+http://search.msn.com/msnbot.htm)
Evidence	

Other Info	
URL	http://www.findmyflick.com/sitemap.xml
Method	GET
Attack	Mozilla/4.0 (compatible; MSIE 6.0; Windows NT 5.1)
Evidence	
Other Info	
URL	http://www.findmyflick.com/sitemap.xml
Method	GET
Attack	Mozilla/4.0 (compatible; MSIE 7.0; Windows NT 6.0)
Evidence	
Other Info	
URL	http://www.findmyflick.com/sitemap.xml
Method	GET
Attack	Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 6.1)
Evidence	
Other Info	
URL	http://www.findmyflick.com/sitemap.xml
Method	GET
Attack	Mozilla/5.0 (Windows NT 10.0; Trident/7.0; rv:11.0) like Gecko
Evidence	
Other Info	
URL	http://www.findmyflick.com/sitemap.xml
Method	GET
Attack	Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/75.0.3739.0 Safari/537.36 Edg/75.0.109.0
Evidence	
Other Info	
URL	http://www.findmyflick.com/sitemap.xml
Method	GET
Attack	Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/91.0.4472.124 Safari/537.36
Evidence	
Other Info	
URL	http://www.findmyflick.com/sitemap.xml
Method	GET
Attack	Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:93.0) Gecko/20100101 Firefox/91.0
Evidence	
Other	

Info	
URL	http://www.findmyflick.com/sitemap.xml
Method	GET
Attack	Mozilla/5.0 (compatible; Googlebot/2.1; +http://www.google.com/bot.html)
Evidence	
Other Info	
URL	http://www.findmyflick.com/sitemap.xml
Method	GET
Attack	Mozilla/5.0 (compatible; Yahoo! Slurp; http://help.yahoo.com/help/us/ysearch/slurp)
Evidence	
Other Info	
URL	http://www.findmyflick.com/sitemap.xml
Method	GET
Attack	Mozilla/5.0 (iPhone; CPU iPhone OS 8_0_2 like Mac OS X) AppleWebKit/600.1.4 (KHTML, like Gecko) Version/8.0 Mobile/12A366 Safari/600.1.4
Evidence	
Other Info	
URL	http://www.findmyflick.com/sitemap.xml
Method	GET
Attack	Mozilla/5.0 (iPhone; U; CPU iPhone OS 3_0 like Mac OS X; en-us) AppleWebKit/528.18 (KHTML, like Gecko) Version/4.0 Mobile/7A341 Safari/528.16
Evidence	
Other Info	
URL	http://www.findmyflick.com/sitemap.xml
Method	GET
Attack	msnbot/1.1 (+http://search.msn.com/msnbot.htm)
Evidence	
Other Info	
Instances	24
Solution	
Reference	https://owasp.org/wstg
CWE Id	
WASC Id	
Plugin Id	10104